MAT 490 INDEPENDENT RESEARCH · ILLINOIS STATE UNIVERSITY

Hybrid Intrusion Detection System

LLM-Augmented Cyber Threat Intelligence Pipeline

Snort 2.9 · XGBoost · GPT-4o mini · LLaMA 3 8B Fine-Tuned

Andy Minga | MAT 490 Independent Research

Supervisor: Dr. Maochao Xu · Illinois State University · Spring 2026

108,172
Confirmed Attacks

99.2%
FP Suppression

$0.000603
GPT-4o mini Cost

$0.00
LLaMA Fine-Tuned

CIC-IDS2017 Wednesday · 13 GB PCAP · 692,703 Network Flows

The Real-World Problem: Alert Fatigue

A SOC Analyst's Morning

[clock] **08:00 AM** — shift starts
[list] 47,382 new Snort alerts overnight
[!] 3,847 flagged "High Priority"
[timer] 8 hours to review
→ **1 alert every 7.5 seconds**

Reality: analysts dismiss alerts without reading them. Real threats get missed.

[!] Target Breach (2013)

40M credit cards stolen. Security tools fired alerts. Analysts did not act in time.

[chart] Industry Statistics (IBM 2023)

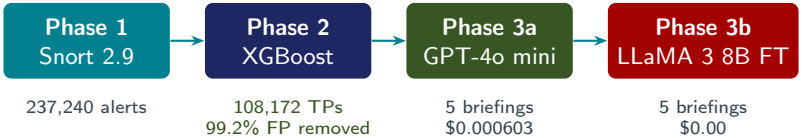
- 45–70% of IDS alerts are **false positives**
- Average breach detection: **197 days**
- Average data breach cost: **$4.45 million**
- SOC analyst avg. tenure: **18–24 months**

Our solution: Reduce 237,240 raw alerts → 108,172 confirmed + AI briefings.

Research Question & Pipeline Overview

"Can a locally-run open-source LLM fine-tuned on domain-specific cybersecurity data produce threat briefings of comparable quality to GPT-4o mini?"

#	Phase	Tool	Output	Cost
1	Detection	Snort 2.9	237,240 alerts (recall 100%)	Free
2	FP Filtering	XGBoost	108,172 confirmed TPs (precision 99%)	Free
3	LLM Baseline	GPT-4o mini	5 briefings, CVE referenced	$0.000603
4	Fine-Tuned LLM	LLaMA 3 8B	5 briefings, $0.00, local & private	$0.00



Dataset : CIC-IDS2017 Wednesday

Canadian Institute for Cybersecurity, University of New Brunswick

How the CIC Built the Data

- Complete lab network with **12 real machines**
- **25 simulated users** with realistic behaviour profiles
- Kali Linux attacker machine outside the firewall
- Attacks launched at **documented exact times** $\Rightarrow$ precise flow labeling
- Total: **50 GB** over 5 days
- Wednesday = most attack-rich day (**13 GB**)

Wednesday attack schedule:
09:47 slowloris · 10:14 Slowhttptest · 10:43 Hulk · 11:10 GoldenEye · 15:12 Heartbleed

Label	Flows	%
BENIGN	440,031	63.5%
DoS Hulk	231,073	33.4%
DoS GoldenEye	10,293	1.5%
DoS slowloris	5,796	0.8%
DoS Slowhttptest	5,499	0.8%
Heartbleed	11	<0.01%
TOTAL	**692,703**	**100%**

File: *`Wednesday-workingHours.pcap_ISCX.csv` (**GeneratedLabelledFlows**; includes IPs)*

Phase 1 : Snort 2.9: The 13 GB Challenge

[!] Memory Problem

- 13 GB PCAP, crashes on load
- Solution: split into **14 chunks** ≈1 GB using `tcpdump -C 1000`
- Each processed independently by Snort
- Results merged: **237,240 alerts** × **31 cols**

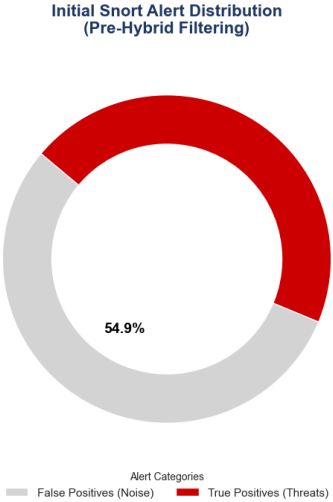
Chunk	Rows	Chunk	Rows
chunk_1	329	chunk_8	78,662
chunk_2	291	chunk_9	76,912
chunk_3	363	chunk_10	29,372
chunk_4	337	chunk_11	7,254
chunk_5	475	chunk_12	6,227
chunk_6	3,499	chunk_13	4,818
chunk_7	24,022	chunk_14	4,679
TOTAL: 237,240 rows — 14/14 successful			

[bug] Column-Shift Bug — fix_row()

Snort skips empty fields instead of writing placeholders. Causes IP addresses to appear in port columns. `fix_row()` scans for the protocol field at expected position 8 and reinserts missing placeholders.

Phase 1 : Initial Snort Alert Distribution

Signal vs noise before XGBoost filtering



Key Takeaways

- **54.9%** of all alerts are noise
- Recall is **100%**; Snort misses only 1 attack
- Problem is precision, not recall
- Snort: *catch everything*
- XGBoost: *filter the noise*

Snort baseline:
TP: 107,107 · FP: 130,133
Precision: 0.4515 · Recall: 1.0000

Phase 2 : XGBoost: Threshold Sweep

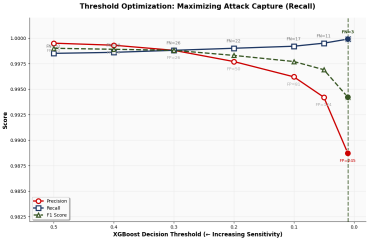
Default 0.50 silently suppressed ∼85,000 real attacks

Threshold	TP	FP	FN	Recall	Prec.	F1
0.50	21,389	10	32	0.9985	0.9995	0.9990
0.40	21,392	16	29	0.9986	0.9993	0.9989
0.30	21,395	26	26	0.9988	0.9988	0.9988
0.20	21,399	50	22	0.9990	0.9977	0.9983
0.10	21,404	81	17	0.9992	0.9962	0.9977
0.05	21,410	124	11	0.9995	0.9942	0.9969
0.01	**21,418**	245	**3**	0.9999	0.9887	0.9942

Test set: 47,448 rows. FN drops 91% (32→3) for only 235 extra alerts

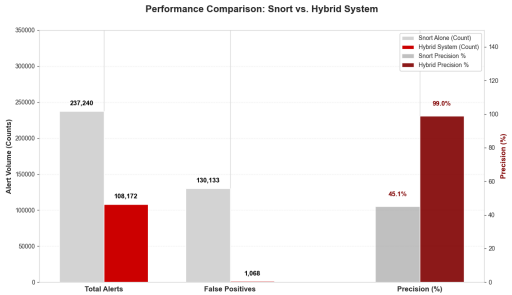
Why Not Use Default 0.50?

At threshold 0.50, XGBoost suppresses ≈**160 real attacks**.
Lowering to 0.01 means allowing alerts with even a 1% probability.
In security, missing attacks is far costlier than false alarms.



Phase 2 : Confirmed True Positive Distribution

108,172 confirmed attacks after XGBoost filtering



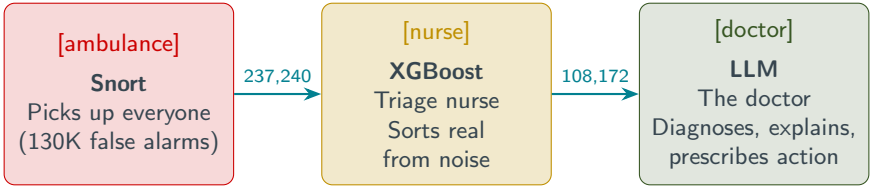
Snort VS Snort + XGBoost.

Attack Type	TPs	%
DoS Hulk	105,257	97.3%
DoS GoldenEye	1,558	1.4%
DoS Slowhttptest	1,073	1.0%
DoS slowloris	279	0.3%
Heartbleed	**5**	<0.01%
TOTAL	108,172	100%

12 Features Used by XGBoost

msg, proto, priority, src_port, dst_port, tcp_flags, tcp_win, ip_len, ip_id, tcp_off, ip_tos, ip_frag

Why XGBoost Is Not Enough : The Doctor Analogy



What XGBoost Cannot Do

After confirming this is a real attack, XGBoost cannot answer:

- What specific attack is this?
- Is there a CVE number?
- Could it steal data or just crash the server?
- What should the analyst do *right now*?
- Should the server go offline?

What the LLM Adds

The LLM reads the raw alert and produces:

- Plain-English attack description
- CVE reference (if one exists)
- Severity rating (Critical/High/Med/Low)
- Step-by-step remediation actions
- Warning signs to watch for

Phase 3a : GPT-4o mini: DoS Attack Briefings

5 API calls · 4,018 tokens · $0.000603 total

DoS Hulk — Severity: Critical

Technique: TCP Reset flood — exhausts server resources
CVE: None (tool-based, not a software flaw)
Warning: High TCP reset traffic; service unavailability
Action: Rate-limit server · firewall suspicious IPs · temporarily increase server resources

DoS GoldenEye — Severity: Critical

Technique: TCP Timestamp manipulation
CVE: None (exploits protocol weakness)
Warning: TCP packets with timestamps outside expected range
Action: Rate-limit · update firewall · review logs

DoS slowloris — Severity: Critical

Technique: Application layer DoS — partial HTTP requests
CVE: None (exploits connection handling)
Warning: High incomplete connections; web unresponsiveness
Action: Rate-limit · WAF · reduce timeout thresholds

DoS Slowhttptest — Severity: High

Technique: Slow HTTP POST — ties up server with partial requests
CVE: None (exploits resource management)
Warning: Slow POST traffic; increased server load
Action: Rate-limit incoming HTTP · monitor logs · firewall

Why High and not Critical? Slower and more detectable than Hulk/GoldenEye. Consistent with lower XGBoost confidence (0.9495 vs 1.0000) — statistically more similar to benign HTTP.

Attack	Alerts	LLM Conf.
DoS Hulk	105,257	1.0000
DoS GoldenEye	1,558	1.0000
DoS Slowhttptest	1,073	0.9495
DoS slowloris	279	0.9999
Heartbleed	5 (all)	—

Phase 3a : Heartbleed: CVE-2014-0160

The only named software vulnerability in the Wednesday dataset

[!] What Makes Heartbleed Different

The 4 DoS attacks exploit *normal server behaviour*: they overwhelm. Heartbleed exploits a *coding error* in OpenSSL 1.0.1–1.0.1f.

The bug: OpenSSL's heartbeat extension never checked whether the claimed packet length was true. Attacker claims "my message is 50,000 bytes" when it is 2 bytes, server responds with 49,998 bytes of its own memory.

Impact: Up to 64 KB of server memory per request. May expose private SSL keys, passwords, session tokens. Attack leaves *no trace* in server logs. Two-thirds of the internet was simultaneously vulnerable.

GPT-4o mini Output — Heartbleed

Severity: **Critical**
CVE: **CVE-2014-0160**

Technique: OpenSSL heartbeat buffer over-read

Recommended actions:

1. Patch OpenSSL to $\geq$1.0.1g immediately
2. Revoke *all* SSL/TLS certificates
3. Rotate all private keys
4. Invalidate all active user sessions
5. Monitor port 444 for further attempts

Only 5 of 11 ground-truth Heartbleed alerts appeared in confirmed TPs. The other 6 were lost during NAT fingerprint matching. The CVE and remediation are independent of alert count.

Model Selection : Why LLaMA 3 8B and Not GPT-2?

× GPT-2 (117M)

- Released 2019 (outdated)
- No instruction following
- No structured JSON output
- Requires full fine-tuning
- Good for learning, not production

∼ Mistral 7B

- Less stable LoRA convergence
- Weaker JSON consistency
- Smaller security ecosystem

✓ LLaMA 3 8B

- Released April 2024
- Native instruction following
- Strong JSON output
- Free for research (Meta)
- Strong CVE reasoning
- LoRA-friendly

Why GPT-2 fails in this pipeline: It was trained only on next-token prediction over web text and not on instruction-response pairs. As a result, it treats prompts as text to continue rather than commands to execute, making reliable structured JSON output unsuitable for automated systems.

Model Architecture : LLaMA 3 8B with LoRA

Class Notebook (GPT-2)

Model	GPT-2 (124M parameters)
Fine-tuning	FULL : all weights
VRAM	<2 GB
Dataset	General Q&A
Prompt	Alpaca format
Training	SFTTrainer
Epochs	1

✓ *Same logic, scaled to 8B with LoRA*

Our Approach (LLaMA 3 8B)

Model	LLaMA 3 8B Instruct (8B params)
Fine-tuning	**LoRA** : 2% of weights
VRAM	$\sim$22 GB (A100)
Dataset	2,618 cybersecurity examples
Prompt	Alpaca format
Training	SFTTrainer
Epochs	8.8 (early stopping)

LoRA: inserts small trainable matrices into attention layers.
Rank 64 · all 7 layers · 167M / 8B = 2.05% trained.
Training time: 38 min on A100. T4 could only manage rank 8.

Why 5 Representative Examples? Selection Strategy

We have 108,172 confirmed alerts; why send only 5 to the LLM?

The LLM generates **one briefing per attack type**. The highest-confidence alert per type is the most representative example.

Attack Type	Count	Confidence
DoS Hulk	105,257	0.999998
DoS GoldenEye	1,558	0.999987
DoS Slowhttptest	1,073	0.949532
DoS slowloris	279	0.999871
Heartbleed	**5**	—

Selection rule: highest XGBoost confidence per attack type = alert whose network signature most clearly matches the attack pattern.

Data Diversity vs Data Quantity

Why we needed external data beyond our own 108,172 alerts

× More Quantity (Same Source)

If we sampled 5,000 from our 108,172 TPs:

- All from UNB lab, July 2017
- All source IPs: 172.16.0.1
- All destination: 192.168.10.50
- Same 5 attack types only

Model memorises *values*, not patterns.
→ **Overfits to one environment**

✓ Better Diversity (3 Sources)

Our 2,618-example strategy:

- **805** original: task format
- **1,610** augmented: varied IPs/ports/flags
- **203** NVD CVEs: real security vocabulary

Model learns *concepts*: DoS = traffic overload, not IP 172.16.0.1.
→ **Generalises to new networks**

Analogy: A doctor who only treats patients from one city fails on patients elsewhere. Diverse training produces general expertise, not city-specific memorisation.

T4 Memory Limitation & Resolution

[!] T4 — The Problem

- T4 VRAM: 15 GB · LLaMA needs ∼16 GB
- Batch: 4→1 · Rank: 64→8
- Seq: 512→256 · Layers: 7→2
- **bitsandbytes** broken (CUDA 12.8)
- 805 examples only
- Val loss: 0.1715
- Perplexity: 46.75 (*worse than base*)

✓ A100 — The Solution

- A100 VRAM: 40 GB (bfloat16)
- Batch: 8 · Rank: 64 (7 layers)
- Sequence: 512 tokens
- No bitsandbytes needed
- 2,618 examples (augmented + NVD)
- Val loss: **0.0883**
- Perplexity: **40.22**

Run	Val Loss	Params	Notes
T4 (rank 8, 805 ex.)	0.1715	3.4M (0.04%)	Limited capacity
A100 (rank 64, 2618 ex.)	**0.0883**	**167M (2.05%)**	**48.5% better**

Preventing Overfitting - Three Strategies

[chart] 5-Fold Cross-Validation

- Split 2,618 into 5 parts
- Train 5 models on 80%
- Mean val loss: **0.1311**
- Std: **0.0065** (very low)
- Low std = consistent generalisation

[stop] Early Stopping

- Max epochs = 10
- Stop if val loss stagnates for 3 consecutive evals
- Stopped at epoch **8.8**
- Best checkpoint: step 1000
- Val loss: **0.0883**

[cycle] Cosine LR Schedule

- Starts high (2e-4)
- Smoothly decreases via cosine curve to ≈0
- 10% warmup prevents early instability
- Better than linear for small domain datasets

Together: model generalises to new unseen alerts rather than memorising the 2,618 training examples

Understanding Perplexity : What It Measures

Perplexity = how "surprised" the model is when reading text
· Lower = better domain understanding

[book] Plain English Analogy

Native speaker reading plain English → **LOW perplexity**

Same person reading specialist cybersecurity jargon → **HIGHER perplexity**

Fine-tuning on CVE data + security text → **perplexity drops**

Formula: Perplexity $= e^{\bar{H}}$ where $\bar{H}$ = average cross-entropy loss over 10 cybersecurity test sentences

Model / Run	Perplexity
Base LLaMA (no FT)	42.78
T4 (r8, 805 ex.)	46.75
A100 (r64, 2618 ex.)	**40.22**

T4 perplexity increased because rank 8 + 805 examples had insufficient capacity. A100 rank 64 + 2,618 diverse examples (including 203 NVD CVEs) improved domain fluency directly.
Note: also discovered lora_alpha=128 caused perplexity 153 at inference. Fixed by patching alpha=32, now automated in Cell 10.

BLEU & ROUGE : Measuring Text Similarity

Comparing LLaMA outputs against GPT-4o mini reference

Why Not Exact Match?

Free-form fields (e.g., `threat_summary`) have **multiple valid phrasings**.

We measure similarity instead of exact correctness between LLaMA outputs and GPT-4o mini references.

BLEU (Precision)

Measures **word overlap (n-grams)**.

Ref: patch OpenSSL immediately
Gen: immediately patch OpenSSL

Matches: patch, OpenSSL

Focus: How much generated text is correct

ROUGE-L (Recall)

Measures **longest shared sequence (LCS)**.

Ref: patch OpenSSL revoke certs
Gen: patch OpenSSL then revoke certs

LCS: patch → OpenSSL → revoke

Focus: How much reference meaning is covered

Fine-tuned LLaMA improves similarity vs base model

BLEU: 0.373 → 0.424 (+13.7%) ROUGE-L: 0.346 → 0.369 (+6.6%)

Results : Full Evaluation Table

Metric	GPT-4o mini	LLaMA Base	LLaMA Fine-Tuned	Δ vs Base
JSON Validity	1.0	1.0	1.0	+0.0
CVE Accuracy	1.0	1.0	1.0	+0.0
Attack ID	1.0	0.6	**1.0 ✓**	**+0.4**
Severity	1.0	0.6	**0.8**	**+0.2**
Technique	1.0	0.134	0.132	−0.002
BLEU	1.0	0.373	**0.424**	+0.051
ROUGE-L	1.0	0.346	**0.369**	+0.023
Perplexity	N/A	42.78	**40.22**	−2.56
Val Loss (train)	N/A	N/A	**0.0883 (A100)**	**−48.5% vs T4**

Fine-tuned model matches GPT-4o mini on 3/7 metrics at $0.00. Technique gap = keyword scoring limitation, not factual error. For zero cost, complete data privacy, and no external API dependency, the fine-tuned model produces briefings that are correct on the facts that matter most : the right attack name, the right CVE, structured output every time, and severity correct on 4 out of 5 attack types. It will not write a briefing as detailed or as precisely worded as GPT-4o mini, but it will not mislead an analyst either.

Evaluation Chart : Visual Results

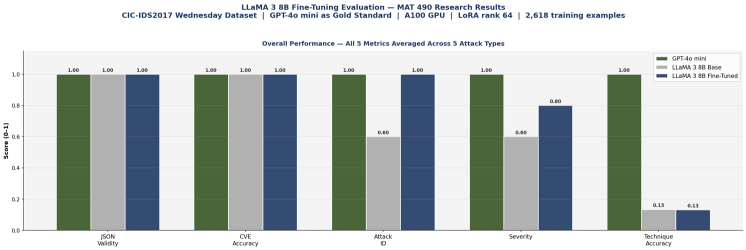


Figure: Overall Performance, all five metrics averaged across 5 Attack types

Attack ID
0.6 → **1.0**
Gap fully closed

Severity
0.6 → **0.8**
Significant gain

BLEU
+13.7%
More similar

Technique
≈ same
Rubric limit

Training Dynamics : Loss Curves

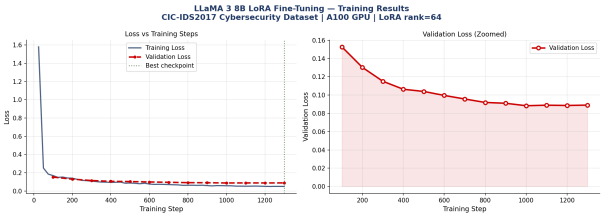


Figure: Training loss vs validation loss over 1300 steps (8.8 epochs). Early stopping fired at step 1300. Best checkpoint: step 1000.

Key Training Facts

Best val loss	**0.0883**
Best step	1000
Stopped epoch	8.8 / 10
Early stop	patience=3
Batch size	8 (A100)
LR schedule	Cosine
Warmup	10%
Optimiser	AdamW

Train loss and val loss *both decreased together*, no overfitting. Val loss plateaued at step 1000, triggering early stopping at step 1300.

Production Output : Before vs After Fine-Tuning

Same 5 alerts through both models

Attack Type	Alerts	Base Severity	FT Severity	Result
DoS Hulk	105,257	High	**Critical**	✓ **FIXED**
DoS GoldenEye	1,558	High	**Critical**	✓ **FIXED**
DoS Slowhttptest	1,073	High	**Critical**	✓ **FIXED**
DoS slowloris	279	High	**Critical**	✓ **FIXED**
Heartbleed	5	Critical	**Critical**	✓ **Maintained**

All 4 DoS severity misclassifications corrected · CVE accuracy maintained · $0.00 cost · 74 seconds total

Honest Limitations & Challenges

Single Dataset

UNB CIC-IDS2017 (July 2017) only. May not generalize to other network environments. Requires retraining for deployment.

Limited Attack Coverage

Only 5 attack types (Wednesday subset). Real-world traffic has far more variants.

Evaluation Gap

Technique accuracy lower (0.13). Mostly due to keyword-based scoring, not model error.

LoRA Alpha Bug

Train: alpha=128 $\rightarrow$ Inference mismatch. Fixed: alpha=32 post-processing patch. Initial perplexity spike (153) resolved.

Future Work

[db] Expand Attack Coverage

- Add CICIDS Thursday & Friday datasets
- Include UNSW-NB15 and KDD Cup 99
- Cover ransomware, SQL injection, XSS
- Target 20+ attack types

[brain] Larger Model — LLaMA 3 70B

- 70B vs 8B parameters
- Multi-GPU A100 cluster
- Expected better technique accuracy
- Test if scale closes remaining gap

[server] Real-Time Deployment

- Apache Kafka stream processing
- Sub-second alert triage
- SIEM integration (Splunk / Elastic)

[ruler] Semantic Evaluation

- Replace keyword technique scoring
- BERTScore for semantic similarity
- Human expert evaluation panel
- More robust than n-gram matching

Real-World Example — Heartbleed in Production

A single Heartbleed alert buried in 237,240 daily alerts

1
Snort flags
5 of 237,240
are Heartbleed
(0.002%)

→

2
XGBoost confirms
Conf. 0.9385
Port 444 ID
Passes 0.01

→

3
LLaMA briefing
JSON in 14s
$0.00
CVE-2014-0160

→

4
Analyst acts
Alert #3 of 486
not #23,451
Response: minutes

Actual Fine-Tuned LLaMA Output:

`attack_type`: "Heartbleed" `severity`: "Critical" `cve_reference`: "CVE-2014-0160"
`threat_summary`: "A confirmed Heartbleed attack has been detected, exposing sensitive data and potentially allowing an attacker to gain unauthorized access to the affected system."
`recommended_action`: "Immediately patch all affected systems, reissue SSL/TLS certificates to prevent further exploitation."

Without pipeline: Heartbleed buried in 237,240 alerts; potentially discovered days later after data exfiltration.

Conclusion

A locally-run fine-tuned LLaMA 3 8B matches GPT-4o mini on 3 of 7 metrics at zero cost

Phase 1+2

Snort + XGBoost reduced 237,240 alerts to 108,172 confirmed threats with 99.2% FP suppression and 100% recall. One rule (NO CONTENT-LENGTH) caused 75% of all false positives.

Phase 3a

GPT-4o mini established the gold standard; 5/5 on all metrics at $0.000603. CVE-2014-0160 correctly identified for Heartbleed. All DoS types correctly briefed.

Phase 3b

Fine-tuned LLaMA 3 8B matched GPT-4o mini on Attack ID (1.0/1.0) and improved severity from 0.6 to 0.8. All 4 DoS severity misclassifications corrected. Cost: $0.00.

Key Finding

A100 + rank 64 + 2,618 diverse examples + early stopping produced 48.5% better validation loss than T4 baseline (0.0883 vs 0.1715).